
title: "W3WI_SE411 - Forschungsseminar Informatik / Advanced Practical IT Security" **lang:** de **author:** "Michael Eichberg" **keywords:** ["IT Sicherheit", "Pentesting"] **description:** "Fortgeschrittene Angewandte IT Sicherheit - Pentesting" **docinfo:** Dozent: "**Prof. Dr. Michael Eichberg**" **Kontakt:** "michael.eichberg@dhbw-mannheim.de, Raum 149B" **Unterlagen:** "Moodle" **Version:** "23SEB (Rev 2026-05-28)" **Id:** id: "2024_08-w3wi_se411-forschungsseminar_informatik-adv._practical_it_security" **first-slide:** "last-viewed"

KI Verwendung: Bei der Erstellung der Unterlagen wurden KI Assistenten (insbesondere Claude aber ggf. auch ChatGPT, Ollama mit Gemma/LLama/Qwen oder OpenCode mit Kimi/Qwen/Deepseek...) unterstützend eingesetzt. Dies erfolgte insbesondere zur Unterstützung bei der Generierung von Grafiken (d. h. SVG Dateien), oder um sich Übersichtstabellen generieren zu lassen. Weiterhin wurde KI zur allgemeinen Qualitätssicherung eingesetzt. Inhalte, die ggf. von der KI vorgeschlagen wurden, wurden im Falle der Übernahme explizit validiert und angepasst.

Teaser

In dieser Veranstaltung werden wir uns mit den Grundlagen praktischer Angriffe und Verteidigungsmaßnahmen im Bereich IT Security auseinandersetzen. Wir werden uns der Frage widmen wie, wann und in welcher Form man - auf den ersten Blick abgesicherte Systeme/geschützte Daten - einerseits angreifen (🚩 *to exploit*) kann und wie man die Sicherheit weiter erhöhen kann.

Wir werden uns in diesem und dem nächsten Semester ausgewählten Themen widmen, die von der Sicherheit von Passwörtern und Angriffen auf selbige bis hin zu der Sicherheit von Netzwerken und Webanwendungen reichen.

Wir werden uns somit auf praktische Aspekte der IT Sicherheit fokussieren. Theoretische Grundlagen sind nur in so weit relevant, dass sie in der Praxis eine Relevanz haben.

✂ Hint

Für diese Veranstaltung sind Grundkenntnisse in Linux/Unix/macOS hilfreich aber nicht notwendig. Notwendig ist aber Interesse an tiefer gehenden technischen Details.

Es wird empfohlen sich eine virtuelle Maschine (z. B. mit VirtualBox) aufzusetzen, auf der Sie Linux (z. B. Kali Linux) installieren. Ggf. können Sie auch WSL2 unter Windows verwenden. Mac User können viele der Tools direkt installieren oder über Homebrew bzw. MacPorts beziehen.

Grober Ablauf

- 1. Semester: 6 Termine; (50% der Endnote)
- 2. Semester: 5 Termine; (50% der Endnote)

Genereller Ablauf

1. Einführung in ein für die IT-Sicherheit relevantes Thema mit praktischer Ausrichtung.
2. Studentische [Präsentationen](#) zur Vertiefung bzw. Betrachtung wichtiger Aspekte.
3. Aufgaben für die entsprechende Fragestellung.
4. Abgaben, die genau beschreiben wie Sie die Aufgaben gelöst haben. Darüber sammeln Sie Teilnoten, die am Ende verrechnet werden. D. h. es gibt Teilnoten pro Aufgabe. Die Punkte sind zwischen den Aufgaben nicht untereinander vergleichbar.

Inhalte

※ Hint

Diese Veranstaltung ist ergänzend zur Veranstaltung SE III IT-Sicherheit zu sehen. D. h. Inhalte, die dort vermittelt werden, werden hier nicht noch einmal behandelt, sind aber potentiell relevant.

1. Semester

1. Passwortwiederherstellung ( *Password Recovery*)
2. Reverse Engineering 101

2. Semester

Pentesting von Webanwendungen

1. Erstes Semester: Passwortwiederherstellung und Reverse Engineering

Was passiert wann im 1. Semester...

19. Nov. 2025:

- Einführung
 - Themenvergabe für die Fachpräsentationen - Notenanteil: 15%
- Die folgenden Themen werden ggf. am 01.12.2025 bzw. 15.12.2025 weiter vorgestellt:

- Einführung in Passwortwiederherstellung (Linux Shell und Reguläre Ausdrücke)
- Einführung in Reverse Engineering

24. November 2025 (Online):

Unterstützung bei der Erstellung der Präsentationen (*Optional*)

BBB: <https://bbb.dhbw.de/rooms/eic-dx8-r7g-ioa>

01. Dezember 2025:

- **Präsentationen (Schwerpunkt: Themen mit Bezug Passwortwiederherstellung)**
- Ausgabe der Übung bzgl. Passwortwiederherstellung ( Password Recovery) - Notenanteil: 15%

15. Dezember 2025:

- **Präsentationen (Schwerpunkt: Themen mit Bezug Reverse Engineering)**
- Ausgabe der Übung bzgl. Reverse Engineering - Notenanteil: 15%

12. Januar 2026 (Online):

Unterstützung bei der Bearbeitung der Aufgaben (*Optional*)

BBB: <https://bbb.dhbw.de/rooms/eic-dx8-r7g-ioa>

21. Januar 2026 (Ereignis):

Abgabe der Lösungen für alle Aufgaben als PDF Dokument über Moodle - Deadline 21.1.2026, 12:00 Uhr

22. Januar 2026 (Ereignis):

Zuteilung wer welchen Teil präsentiert über Moodle/Mail. Sollten Sie am 22.01. bis 19:00 Uhr weder eine Nachricht in Moodle noch eine E-Mail von mir erhalten haben, dann *melden Sie sich bitte umgehend* bei mir.

26. Januar 2026:

Abschlusspräsentationen - Notenanteil: 5%

Die Präsentationsdauer pro Person ist 5 Minuten und soll die Vorgehensweise zur Lösung der entsprechenden Aufgabe präsentieren. D. h. die Präsentation kann auch eine „Live-Demo“ sein, die zeigt wie die Aufgabe gelöst wurde.

[Erste Tips zur Gestaltung von Vorträgen finden Sie hier.](#)

Sollten Sie eine Live-Demo machen, dann zeichnen Sie Ihren Probelauf auf (5 Minuten) und laden Sie diesen als Zip-Datei hoch. Alternativ können Sie Ihr Video auch in Youtube stellen oder per OneDrive, Dropbox, ... zur Verfügung stellen. In diesem Falle laden Sie eine Textdatei mit der URL zum Video hoch! Das Video soll mindestens 3 Monate verfügbar sein.

Notenzusammenstellung - 1. Semester

Leistungsnachweis	Notenanteil
Fachpräsentation (10 Minuten pro Person)	15%
Lösungen der Aufgaben bzgl. Passwortwiederherstellung	15%
Lösungen der Aufgaben bzgl. Reverse Engineering	15%
Lösungspräsentationen (5 Minuten pro Person)	5%

Fachpräsentationen

Vortragsthemen 1.12.2025

- scrypt, bcrypt und Argon2: moderne Passwort Hashing Algorithmen - Vorstellung und Shout-out
(3 Personen)
- John the Ripper: Passwort Cracking Tool - Einführung und Demonstration
(1 Person)
- WIFI Passwortsicherheit: Hacking WEP und WPA2 mit Aircrack-ng - Einführung und Demonstration;
WPA3: [Besprechung von Dragonblood](#)
(2 Personen)
- Wireshark: Einführung in die Konzepte und praktische Anwendung (Kali Linux, Mac OS, Windows) -
Anwendung bei verschlüsselten Protokollen (TLS, HTTPS, ...)
(3 Personen)
- YSoSerial: Java Deserialization Exploits (aka Serialization gadgets) - Einführung in das Thema und
Demonstration/Besprechung von Beispielen
(2 Person)
- Fuzzy Hashing und Yara: Malware Detection/Description
(1 Person)

Vortragsthemen 15.12.2025

- Aufbau von APKs (Android Apps) und der grobe Aufbau des Dex File Formats
(2 Person)
- DexGuard und Proguard: Obfuscator für Android und Java Anwendungen - Einführung und
Demonstration (z.B. mit Hilfe von Jadx, CFR/JD-GUI)
(1 Personen)
- Einsatz von FRIDA zur dynamischen Instrumentierung von Android und iOS Anwendungen
(1 Personen)
- xdbg64 (Windows): Hacking Applications mit dem x64 Debugger - Einführung und Demonstration
(1 Person)
- Native Binary Reverse Engineering
(Bitte Gegenseitig absprechen, um Überschneidungen zu vermeiden!)
 - Assembler: x86 oder ARM Assembler Grundlagen für Reverse Engineering
(2 Personen)
 - *Function Call Semantics* in Binaries und *Syscalls*
(1 Person)
 - Virtuelle Methodenaufrufe und deren Umsetzung in Assembler
(1 Person)
 - Sicherheitsmechanismen in Native-Binaries: insbesondere Stack canaries, Position-independent
Code & Address Space Layout Randomization
(1 Person)
 - Ghidra: Binary-Reverse-Engineering - kurze Einführung und Demonstration
(2 Personen)

Themenvergabe

Thema	Personen
scrypt, bcrypt und Argon2	3
John the Ripper	1
WIFI Passwortsicherheit	2
Wireshark	3
YSoSerial	2
Fuzzy Hashing und Yara	1
Aufbau von APKs und Dex	2
DexGuard und Proguard	1
FRIDA	1
xdbg64	1
Assembler Einführung	2
<i>Function Call Semantics</i>	1
Virtuelle Methodenaufrufe	1
Sicherheitsmechanismen in Native-Binaries	1
Ghidra	2

Bewertete Abgaben

1. [Passwortwiederherstellung - Aufgaben](#)
2. [Reverse Engineering - Aufgaben](#)

2. Zweites Semester: Pentesting von Webanwendungen

▲ Attention!

Geänderte Bewertungskriterien für alle Formen von Abgaben (Präsentationen, Dokumentationen).

Zu Punktabzügen führen:

- Aussagen, die faktisch falsch oder unsinnig sind
- Aussagen, die überflüssig sind („*Blah Blah*“) und nicht dem Kernthema der Präsentation zugeordnet werden können
- Unnötige Aussagen, die bekannte Inhalte (zum Beispiel aus dieser oder anderen Vorlesungen) wiederholen
- Aussagen, die nicht durch eine Quelle oder durch eigene Experimente belegt werden können
- Qualifizierende Attribute („schneller“, „besser“, „schwerer“ ...), die nicht durch konkrete Metriken belegt bzw. definiert werden

Ablauf

- 20.05.2026:**
- Ausgabe der Themen zur Bearbeitung
 - Kurze Einführung in das Thema Pentesting
- 01.06.2026:**
- Bearbeitung der Themen mit dem Ziel „Hands-on“
 - Ich stehe für Rückfragen *online* (<https://bbb.dhbw.de/rooms/eic-uue-f52-6xb/join>) zur Verfügung
- 08.06.2026:**
- Halten der Präsentationen (Doppeltermin)
Thema 1 bis 12
- 15.06.2026:**
- Halten der Präsentationen
Thema 13 bis 18
- 02.07.2026 - Online:**
- Ausgabe der Pentesting-Aufgabe
- 31.07.2026 (Prüfungsgespräche)**
- Gruppenindividuelle Prüfungsgespräche (8 Gruppen)

Vortragsthemen - Grundlagen

Dauer pro Person: 15 Minuten

- [1 Person] Grenzen der Multi-Faktor-Authentifizierung
(MFA fatigue, [Token Theft](#), ...)
- [1 Person] [Shodan](#) and OSINT im Pentesting
- [1 Person] Server-Side Request Forgery ([Portswigger - SSRF](#))
(Ggf. inkl. Demonstration und Erklärung wie man sich schützt.)
- [2 Personen] [MITRE ATT&CK](#)
(Knowledge base of adversary tactics and techniques based on real-world observations.)
 1. Person - allgemeine Einführung
 2. Person - Darstellung ausgewählter Themen
(Bitte darauf achten, dass es mit den OWASP Vorträgen zu keinen relevanten Überschneidungen kommt.)
- [1 Person] [OWASP Web Security Testing Guide](#)
- [1 Person] [OWASP Mobile Application Security](#)
- [1 Person] Copy Fail (<https://copy.fail>) (case study)
Als Case-study aufarbeiten und auch die Entstehungsgeschichte erklären. Bitte auch in Relation zu den entsprechenden klassischen Sicherheitsprinzipien von Saltzer und Schroeder (1975) setzen.
- [1 Person] [Scapy](#)
(Interactive packet manipulation library)
Eine Demo ist sehr wünschenswert.
- [1 Person] [OpenVAS - Community Edition \(Scanner\)](#)
(Vulnerability Testing)
Achtung: bei der Community Edition handelt es sich wohl um ein „rohes Produkt“.
- [2 Personen] [OWASP Top Ten 2025](#) (z. B. 1. Person Lücke 1-5; 2. Person Lücke 6 - 10; die konkrete Einteilung ist aber freigestellt!)
Jeweils mit konkreten Beispielen in etablierten Sprachen/Frameworks.
- [2 Personen] [OWASP Top Ten for LLM Applications](#) (z. B. 1. Person Lücke 1-5; 2. Person Lücke 6 - 10; die konkrete Einteilung ist aber freigestellt!)
- [1 Person] Wireshark für Pentester
Fokus auf: typische Filter, Credentials finden, verdächtige Muster
- [1 Person] [Gobuster](#)
(A directory/file, DNS and virtual host brute-forcing tool)

Vortragsthemen - Angewandt

Dauer pro Person: 15 Minuten

▲ Attention!

Niemand, der eines der folgenden Themen bearbeitet, darf mit jemand anderem aus dieser Gruppe bei der Bearbeitung der Portfolioaufgabe zusammenarbeiten.

■ [1 Person] [Nmap \(und ncat\)](#)

(Network discovery and security auditing.)

■ [2 Personen] [Zed Attack Proxy \(ZAP\)](#)

(Web App Scanner)

1. Einführung (inkl. Marketplace)
2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführen und dann ZAP demonstrieren!)

■ [2 Personen] [Burp Suite](#)

(Penetration testing toolkit.)

1. Einführung (inkl. Marketplace)
2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführen und dann Burp Suite demonstrieren!)

■ [2 Personen] [Metasploit \(Open Source\)](#)

(Penetration testing framework.)

1. Einführung in Metasploit - d. h. Architektur und Aufbau von Metasploit
2. Live Demo (bitte erst in das Szenario einführen)

■ [1 Person] [Nikto](#)

(Open-source web server scanner checking for dangerous or interesting files and programs, identifying outdated versions of servers and components, detecting common server misconfigurations such as multiple index files, HTTP server options, and more.)

Themenverteilung

Nr.	Thema	#Stud.	1. Student	2. Student
1.	MFA	1	Wrede	
2.	OSINT	1	Weber	
3.	SSRF	1	Clauss	
4.	ATT&CK	2	Teschke	Tikce
5.	OWASP - WSTG	1	Stammer	
6.	OWASP - MAS	1	Wieder	
7.	Gobuster	1	Müller	
8.	Scapy	1	Saado	
9.	OpenVAS	1	Singh	
10.	OWASP Top Ten	2	Pjano	Korten
11.	OWASP Top Ten for LLM Apps	2	Erhard	Bäck
12.	Wireshark	1	Jun	
13.	Copy Fail	1	Plett	
14.	Nmap	1	Molter	
15.	ZAP	2	Priemer	Meli
16.	Burp	2	Stahl	Zweigert
17.	Metasploit	2	Meinel	Sönmez
18.	Nikto	1	Kling	

Bewertungskriterien

Für die Präsentation Ihres Fachvortrags

■ Hinweise für Präsentationen

■ Notenanteil: 25% von der Gesamtnote - d.h. 30 Punkte:

■ 29 Punkte für den Vortrag

Der Vortrag muss am Tag der Präsentation bis spätestens 7:00 Uhr hochgeladen sein.

Für die Teile, die sie demonstrieren, laden Sie bitte eine ausreichende Anzahl an Screenshots (in einem PDF) hoch, damit nachvollzogen werden kann, was demonstriert wurde; alternativ können Sie einen Screencast Ihrer Demo erstellen und diesen *direkt* nach Ihrem Vortrag hochladen.

■ 1 Punkt für das Ausfüllen, Gegenzeichnen und zeitgerechte Hochladen der [Checkliste](#)

Bei Gruppenarbeit hat dies jeder Studierende eigenständig zu machen; es erfolgt keine Abgabe der Checkliste für die Gruppe.

Für die mündliche Prüfung (31.7. - Raum 261C)

■ Anzahl und Art der gefundenen Schwachstellen

Fertigen Sie ein Dokument (.md, .pdf) an, dass Sie vorher (siehe Moodle) hochladen und in dem Sie die Lücken kurz dokumentieren. Pro Lücke dokumentieren Sie den Server + die Anwendung/den API Endpunkt/... der Vulnerabel ist und mit welchem CWE die Lücke verknüpft ist. Sollte Sie kein CWE finden, dann schreiben Sie ein/zwei Sätze, um die Lücke zu charakterisieren.

▲ Attention!

Eine detaillierte Dokumentation ist nicht erforderlich, da es sich im wesentlichen, um ein Prüfungsgespräch handelt. Es geht hier ausschließlich um eine knappe Auflistung der Lücken! Eine Beschreibung der Lücken oder wie diese gefixt werden könnten ist nicht gewünscht.

Der Einsatz von KI zur Erstellung/Verbesserung der Liste ist strikt untersagt.

Wir werden diese Liste als Start für das Prüfungsgespräch verwenden.

■ Demonstration der Schwachstellen

Bringen Sie (mind.) einen Rechner mit, auf dem Sie alle Tools etc. installiert haben, und mit dem Sie in der Lage sind die Lücke unmittelbar zu demonstrieren.

Das Anlegen von (kleineren) Scripten ist ggf. empfohlen.

■ Beantwortung von Fragen

Jeder muss zu jeder Lücke sprechfähig sein.

■ Notenanteil: 25% von der Gesamtnote - d. h. 30 Punkte:

■ Dauer: ca. 25 Minuten pro Gruppe

Teilnahme am Pentest

Laden Sie bis zum 3. Juli 7:00 Uhr, Ihre Bestätigung der Teilnahmebedingungen hoch.

Gruppenzuteilung Pentesting

Datum: 31.7.2026

Ort: 261 C

#	Uhrzeit	1. Stud.	2. Stud.	3. Stud.
1	8:30	Ibrahim Tikce	Nils Teschke	Iven Stahl
2	9:10	Ramona Korten	Monika	Sergio Meli
3	9:50	Tarnbir Singh	Christian Zweigert	Jan Müller
4	10:30	Tom Weber	Paulina Clauss	Lisa Molter
5	11:10	Max Meinel	Dilmand Sado	Nico Wrede
6	13:30	Jonathan Wieder	Jonas Stammer	Leon Primer
7	14:10	Mika Jun	Raphael Plett	Okan Sönmez
8	14:50	Luca Bäck	Felix Erhard	Johannes Kling

Pentesting

Die folgenden Server dürfen Sie einem Pentest unterziehen:

Server	Komplexität
141.72.13.218	*
141.72.12.145	**
141.72.12.138	**
<i>four-wins.michael-eichberg-at-dhbw-de.users.dhbw.site</i>	**
141.72.176.151	* _ **
(ab 4. Juli)	
141.72.12.141	***
<i>quizzzy.michael-eichberg-at-dhbw-de.users.dhbw.site</i>	

Legend

* = einfach; *** = sehr schwer

!DANGER!

Unter keinen Umständen dürfen Sie andere als die hier gelisteten Server *angreifen*. Scans von Subdomänen (es gibt auch keine) oder anderen IP-Adressen sind untersagt.

Sie dürfen auch immer nur die hier beschriebenen Angriffe/Änderungen vornehmen. Jegliche darüber hinausgehenden Tätigkeiten sind untersagt.

Hint

Pentesting der VMs ist nur aus dem Netz der DHBW heraus möglich. D. h. nur wenn Sie eine IP-Adresse im Bereich 141.72.0.0/16 haben. Nutzen Sie eine VM auf OpenStack, dann stellen Sie sicher, dass diese VM keine Egress-Filterung vornimmt und im richtigen Netz ist (ggf. in den Security-Policies zu konfigurieren). Wenn Sie sich per VPN verbinden, dann sollte dies immer der Fall sein.

Pentesting - Rahmenbedingungen

Was ist erlaubt/was nicht...

- Metasploit ist nicht zu verwenden, erfolgreiche Angriffe mit Metasploit werden nicht anerkannt.
- Horizontale Privilegienerweiterungen, sind nicht prüfungsrelevant.
- Alle Sicherheitslücken, die ggf. direkt auf die Verwendung von HTTP zurückzuführen sind, sind zu ignorieren!
- Sollten Sie ggf. auf Informationen über Nutzeraccounts stoßen oder selbige angreifen wollen, dann **nehmen Sie den Nutzeraccount/Gruppenaccount, der zu Ihrer Gruppennummer gehört.**
- Möchten Sie auf einem Server Daten ablegen, dann legen Sie diese auf jeden Fall **nur** in dem Verzeichnis ab, der zu Ihrer Gruppennummer passt! (/home/gruppe<N>, /home/group<N>, ...)
- Sollten Sie Zugriff auf einen Server bekommen - sei es als normaler Nutzer oder als Root-Nutzer - dann dürfen Sie sich auf jeden Fall frei umsehen.
- Die Server haben ggf. viele Schwachstellen; die aber bei Weitem nicht alle gleich einfach auszunutzen sind; suchen Sie die einfachste!
- Bei den Webanwendungen sollten Sie versuchen, so viele verschiedene Schwachstellen wie möglich zu finden. Mappen Sie Ihre Schwachstelle auch immer auf eine CWE! Schwachstellen, den immer nur dieselbe CWE zugrunde liegt, wird nur als eine Schwachstelle gewertet.
- Bei allen Aktionen bedenken Sie, dass auch andere Personen an dem Pentest teilnehmen und eine Einschränkung anderer Personen nicht gestattet ist.
- Sie dürfen keine Maßnahmen durchführen, die die Verfügbarkeiten der Server dramatisch einschränken.
- Sie dürfen unter keinen Umständen Veränderungen oder Aktualisierungen an den Servereinstellungen vornehmen, sollten Sie auf einem oder mehreren Servern Root-Access erlangen!
- Die Struktur von Datenbanken (**alter** . . .) darf nicht verändert werden; semantisch sinnvolle Datensätze, um zum Beispiel die Privilegien eines Nutzer zu erweitern, dürfen hinzugefügt werden (**update** . . .). Daten, die zur Anwendungslogik gehören, dürfen nicht gelöscht werden!
- Untersagt sind darüber hinaus sämtliche Handlungen, die ein verständiger Teilnehmer bei objektiver Betrachtung als nicht vom Zweck der Veranstaltung gedeckt erkennen muss — unabhängig davon, ob sie in diesen Bedingungen ausdrücklich aufgeführt sind. Die vorstehenden Verbote sind beispielhaft, nicht abschließend zu verstehen.

♦ Remark

Sollten Sie auf Probleme stoßen, dann melden Sie sich bitte sowohl **bei Herrn Rutesic** als auch bei mir per Mail.

⚠ Warning

Für eine Teilnahme an dem Pentest ist die Gegenzeichnung bis zum 3. Juli 2026 7:00 Uhr erforderlich und *persönlich* im Moodle hochzuladen.

Datum: _____

Unterschrift: _____

